



ZAP by
Checkmarx

OWASP ZAP Frontend

Cuidarte+ :3333

Sitios: <http://localhost:4444> <http://localhost:3333>

Generado a mar, 8 sept 2026 00:01:01

ZAP Versión: 2.17.0

ZAP by [Checkmarx](#)

Sumario de Alertas

Nivel de riesgo	Número de Alertas
Alto	0
Medio	4
Bajo	4
Informativo	1

Insights

Level	Razón	Site	Descripción	Statistic
Bajo	Advertencia		ZAP errors logged - see the zap. log file for details	3
Bajo	Advertencia		ZAP warnings logged - see the zap. log file for details	5
Información	Informativo		Percentage of network failures	9 %
Información	Informativo	http://localhost:3333	Percentage of responses with status code 2xx	60 %
Información	Informativo	http://localhost:3333	Percentage of responses with status code 3xx	34 %
Información	Informativo	http://localhost:3333	Percentage of responses with status code 4xx	4 %

Información	Informativo	http://localhost:3333	Percentage of endpoints with content type application/javascript	16 %
Información	Informativo	http://localhost:3333	Percentage of endpoints with content type image/svg+xml	16 %
Información	Informativo	http://localhost:3333	Percentage of endpoints with content type text/css	16 %
Información	Informativo	http://localhost:3333	Percentage of endpoints with content type text/html	50 %
Información	Informativo	http://localhost:3333	Percentage of endpoints with method GET	100 %
Información	Informativo	http://localhost:3333	Count of total endpoints	6
Información	Informativo	http://localhost:4444	Percentage of responses with status code 2xx	100 %
Información	Informativo	http://localhost:4444	Percentage of endpoints with content type application/json	100 %
Información	Informativo	http://localhost:4444	Percentage of endpoints with method GET	100 %
Información	Informativo	http://localhost:4444	Count of total endpoints	1

Alertas

Nombre	Nivel de riesgo	Número de Instancias
Cabecera Content Security Policy (CSP) no configurada	Medio	3

Configuración Incorrecta Cross-Domain	Medio	1
Falta atributo de integridad de recursos secundarios	Medio	Systemic
Falta de cabecera Anti-Clickjacking	Medio	3
Divulgación de Marcas de Tiempo - Unix	Bajo	1
El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP ""X-Powered-By""	Bajo	1
El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP	Bajo	Systemic
Falta encabezado X-Content-Type-Options	Bajo	Systemic
Aplicación Web Moderna	Informativo	3

Detalles de la Alerta

Medio	Cabecera Content Security Policy (CSP) no configurada
Descripción	La Política de seguridad de contenido (CSP) es una capa adicional de seguridad que ayuda a detectar y mitigar ciertos tipos de ataques, incluidos Cross Site Scripting (XSS) y ataques de inyección de datos. Estos ataques se utilizan para todo, desde el robo de datos hasta la desfiguración del sitio o la distribución de malware. CSP proporciona un conjunto de encabezados HTTP estándar que permiten a los propietarios de sitios web declarar fuentes de contenido aprobadas que los navegadores deberían poder cargar en esa página; los tipos cubiertos son JavaScript, CSS, marcos HTML, fuentes, imágenes y objetos incrustados como applets de Java, ActiveX, archivos de audio y video.
URL	http://localhost:3333
Nombre del Nodo	http://localhost:3333
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:3333/robots.txt
Nombre del Nodo	http://localhost:3333/robots.txt
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:3333/sitemap.xml
Nombre del Nodo	http://localhost:3333/sitemap.xml
Método	GET
Ataque	
Evidencia	
Otra información	

Instancia	3
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. esté configurado para establecer la cabecera Content-Security-Policy.
Referencia	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medio	Configuración Incorrecta Cross-Domain
Descripción	La carga de datos del navegador web puede ser posible, debido a una mala configuración de Cross Origin Resource Sharing (CORS) en el servidor web.
URL	http://localhost:4444/
Nombre del Nodo	http://localhost:4444/
Método	GET
Ataque	
Evidencia	Access-Control-Allow-Origin: *
Otra información	La configuración incorrecta de CORS en el servidor web permite solicitudes de lectura entre dominios de terceros arbitrarios, utilizando API no autenticadas en este dominio. Sin embargo, las implementaciones de los navegadores web no permiten que terceros arbitrarios lean la respuesta de las API autenticadas. Esto reduce un poco el riesgo. Esta configuración errónea podría ser utilizada por un atacante para acceder a datos que están disponibles de forma no autenticada, pero que utilizan alguna otra forma de seguridad, como la lista blanca de direcciones IP.
Instancia	1
Solución	Asegúrese de que los datos confidenciales no estén disponibles de forma no autenticada (por ejemplo, mediante listas blancas de direcciones IP). Configure el encabezado HTTP "Access-Control-Allow-Origin" a un conjunto más restrictivo de dominios, o elimine todos los encabezados CORS por completo, para permitir que el navegador web aplique la Política del Mismo Origen (SOP) de una manera más restrictiva.
Referencia	https://vulnecat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy
CWE Id	264
WASC Id	14
Plugin Id	10098

Medio	Falta atributo de integridad de recursos secundarios
Descripción	Falta el atributo de integridad en una etiqueta de script o enlace servida por un servidor externo. La etiqueta de integridad evita que un atacante que haya obtenido acceso a este servidor inyecte un contenido malicioso.
URL	http://localhost:3333
Nombre del Nodo	http://localhost:3333
Método	GET

Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Poppins:ital,wght@0,100;0,200;0,300;0,400;0,500;0,600;0,700;0,800;0,900;1,100;1,200;1,300;1,400;1,500;1,600;1,700;1,800;1,900&display=swap" rel="stylesheet" />
Otra información	
URL	http://localhost:3333
Nombre del Nodo	http://localhost:3333
Método	GET
Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Rubik:wght@300;400;500;600;700&display=swap" rel="stylesheet" />
Otra información	
URL	http://localhost:3333/robots.txt
Nombre del Nodo	http://localhost:3333/robots.txt
Método	GET
Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Poppins:ital,wght@0,100;0,200;0,300;0,400;0,500;0,600;0,700;0,800;0,900;1,100;1,200;1,300;1,400;1,500;1,600;1,700;1,800;1,900&display=swap" rel="stylesheet" />
Otra información	
URL	http://localhost:3333/robots.txt
Nombre del Nodo	http://localhost:3333/robots.txt
Método	GET
Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Rubik:wght@300;400;500;600;700&display=swap" rel="stylesheet" />
Otra información	
URL	http://localhost:3333/sitemap.xml
Nombre del Nodo	http://localhost:3333/sitemap.xml
Método	GET
Ataque	
Evidencia	<link href="https://fonts.googleapis.com/css2?family=Poppins:ital,wght@0,100;0,200;0,300;0,400;0,500;0,600;0,700;0,800;0,900;1,100;1,200;1,300;1,400;1,500;1,600;1,700;1,800;1,900&display=swap" rel="stylesheet" />
Otra información	
Instancia	Systemic
Solución	Proporcionar un atributo de integridad válido a la etiqueta.
Referencia	https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity
CWE Id	345

WASC Id	15
Plugin Id	90003

Medio	Falta de cabecera Anti-Clickjacking
Descripción	La respuesta no protege contra ataques de "ClickJacking". Debes incluir Content-Security-Policy con la directiva "frame-ancestors" o X-Frame-Options.
URL	http://localhost:3333
Nombre del Nodo	http://localhost:3333
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:3333/robots.txt
Nombre del Nodo	http://localhost:3333/robots.txt
Método	GET
Ataque	
Evidencia	
Otra información	
URL	http://localhost:3333/sitemap.xml
Nombre del Nodo	http://localhost:3333/sitemap.xml
Método	GET
Ataque	
Evidencia	
Otra información	
Instancia	3
Solución	Los navegadores web modernos admiten las cabeceras HTTP Content-Security-Policy y X-Frame-Options. Asegúrese de que una de ellas está configurada en todas las páginas web devueltas por su sitio/aplicación. Si espera que la página esté enmarcada solo por páginas en su servidor (por ejemplo, si forma parte de un FRAMESET), utilice SAMEORIGIN; de lo contrario, si no espera que la página esté enmarcada, utilice DENY. Alternativamente, considere implementar la directiva "frame-ancestors" de la Política de Seguridad de Contenidos.
Referencia	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Bajo	Divulgación de Marcas de Tiempo - Unix
Descripción	Una marca de tiempo fue revelada por la aplicación/servidor web. - Unix
URL	http://localhost:3333/assets/index-BjQUO07R.js
Nombre	

del Nodo	http://localhost:3333/assets/index-BjQUO07R.js
Método	GET
Ataque	
Evidencia	1540483477
Otra información	1540483477, que se evalúa como: 2018-10-25 13:04:37.
Instancia	1
Solución	Confirmar que los datos encontrados de información sobre la marca de tiempo no son sensibles, ni se pueden usar en patrones explotables de divulgación.
Referencia	https://cwe.mitre.org/data/definitions/200.html
CWE Id	497
WASC Id	13
Plugin Id	10096

Bajo	El servidor divulga información mediante un campo(s) de encabezado de respuesta HTTP ""X-Powered-By""
Descripción	El servidor de la web/aplicación está divulgando información mediante uno o más encabezados de respuesta HTTP ""X-Powered-By"". El acceso a tal información podría facilitarle a los atacantes la identificación de otros marcos/componentes de los que su aplicación web depende y las vulnerabilidades a las que pueden estar sujetos tales componentes.
URL	http://localhost:4444/
Nombre del Nodo	http://localhost:4444/
Método	GET
Ataque	
Evidencia	X-Powered-By: Express
Otra información	
Instancia	1
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. está configurado para suprimir las cabeceras "X-Powered-By".
Referencia	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Bajo	El servidor filtra información de versión a través del campo "Server" del encabezado de respuesta HTTP
Descripción	El servidor web/aplicación está filtrando información de versión a través de la cabecera de respuesta HTTP "Server". El acceso a dicha información puede facilitar a los atacantes la identificación de otras vulnerabilidades a las que está sujeto su servidor web /aplicación.
URL	http://localhost:3333
Nombre del Nodo	http://localhost:3333
Método	GET

Ataque	
Evidencia	nginx/1.31.5
Otra información	
URL	http://localhost:3333/assets/index-BY5Enl6a.css
Nombre del Nodo	http://localhost:3333/assets/index-BY5Enl6a.css
Método	GET
Ataque	
Evidencia	nginx/1.31.5
Otra información	
URL	http://localhost:3333/robots.txt
Nombre del Nodo	http://localhost:3333/robots.txt
Método	GET
Ataque	
Evidencia	nginx/1.31.5
Otra información	
URL	http://localhost:3333/sitemap.xml
Nombre del Nodo	http://localhost:3333/sitemap.xml
Método	GET
Ataque	
Evidencia	nginx/1.31.5
Otra información	
URL	http://localhost:3333/vite.svg
Nombre del Nodo	http://localhost:3333/vite.svg
Método	GET
Ataque	
Evidencia	nginx/1.31.5
Otra información	
Instancia	Systemic
Solución	Asegúrese de que su servidor web, servidor de aplicaciones, balanceador de carga, etc. está configurado para suprimir la cabecera "Server" o proporcionar detalles genéricos.
Referencia	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Bajo

Falta encabezado X-Content-Type-Options

Descripción	La cabecera Anti-MIME-Sniffing X-Content-Type-Options no se ha establecido en 'nosniff'. Esto permite que las versiones anteriores de Internet Explorer y Chrome realicen MIME-sniffing en el cuerpo de la respuesta, lo que puede provocar que el cuerpo de la respuesta se interprete y se muestre como un tipo de contenido distinto del tipo de contenido declarado. Las versiones actuales (principios de 2014) y heredadas de Firefox utilizarán el tipo de contenido declarado (si se establece uno), en lugar de realizar MIME-sniffing.
URL	http://localhost:3333
Nombre del Nodo	http://localhost:3333
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:3333/assets/index-BY5Enl6a.css
Nombre del Nodo	http://localhost:3333/assets/index-BY5Enl6a.css
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:3333/robots.txt
Nombre del Nodo	http://localhost:3333/robots.txt
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:3333/sitemap.xml
Nombre del Nodo	http://localhost:3333/sitemap.xml
Método	GET
Ataque	
Evidencia	

Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:3333/vite.svg
Nombre del Nodo	http://localhost:3333/vite.svg
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
URL	http://localhost:4444/
Nombre del Nodo	http://localhost:4444/
Método	GET
Ataque	
Evidencia	
Otra información	Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.
Instancia	Systemic
Solución	Asegúrese de que la aplicación/servidor web establece el encabezado Content-Type adecuadamente, y que establece el encabezado X-Content-Type-Options a 'nosniff' para todas las páginas web. Si es posible, asegúrese de que el usuario final utiliza un navegador web moderno y compatible con los estándares que no realiza MIME-sniffing en absoluto, o que puede ser dirigido por la aplicación web/servidor web para que no realice MIME-sniffing.
Referencia	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security-Headers
CWE Id	693
WASC Id	15
Plugin Id	10021
Informativo	Aplicación Web Moderna
Descripción	La aplicación parece ser una aplicación web moderna. Si necesita explorarla automáticamente, el Ajax Spider puede ser más eficaz que el estándar.
URL	http://localhost:3333
Nombre del Nodo	http://localhost:3333

Método	GET
Ataque	
Evidencia	<script type="module" crossorigin src="/assets/index-BjQUO07R.js"></script>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
URL	http://localhost:3333/robots.txt
Nombre del Nodo	http://localhost:3333/robots.txt
Método	GET
Ataque	
Evidencia	<script type="module" crossorigin src="/assets/index-BjQUO07R.js"></script>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
URL	http://localhost:3333/sitemap.xml
Nombre del Nodo	http://localhost:3333/sitemap.xml
Método	GET
Ataque	
Evidencia	<script type="module" crossorigin src="/assets/index-BjQUO07R.js"></script>
Otra información	No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.
Instancia	3
Solución	Se trata de una alerta informativa, por lo que no es necesario realizar ningún cambio.
Referencia	
CWE Id	
WASC Id	
Plugin Id	10109